

Nota de Estudo 2

TLS

As técnicas criptográficas podem fornecer confidencialidade, integridade de dados e autenticação de ponto final para uma aplicação específica, ou seja, e-mail. A criptografia pode aprimorar o TCP com serviços de segurança, incluindo confidencialidade, integridade de dados e autenticação de ponto final. Essa versão aprimorada do TCP é comumente conhecida como Segurança da Camada de Transporte (TLS), padronizada pela IETF [RFC 4346]. Uma versão anterior e semelhante desse protocolo é o SSL versão 3.

O protocolo SSL foi originalmente projetado pela Netscape. Desde sua criação, o SSL e seu sucessor, o TLS, têm desfrutado de ampla implantação. O TLS é suportado por todos os navegadores e servidores Web populares e é usado pelo Gmail e essencialmente por todos os sites de comércio eletrônico.

Para entender a necessidade do TLS, vamos analisar um cenário típico de comércio eletrônico. Bob está navegando na internet e acessa o site da Alice Incorporated, que vende perfumes. O site da Alice Incorporated exibe um formulário no qual Bob deve inserir o tipo de perfume e a quantidade desejada, seu endereço e o número do seu cartão de pagamento. Bob insere essas informações, clica em Enviar e espera receber (por correio comum) os perfumes comprados; ele também espera receber uma cobrança pelo seu pedido na próxima fatura do seu cartão de pagamento. Bob poderá ter algumas surpresas:

- Se nenhuma confidencialidade (criptografia) for utilizada, um invasor poderá interceptar o pedido de Bob e obter as informações do seu cartão de pagamento. O invasor poderá então fazer compras às custas de Bob.
- Se nenhuma integridade de dados for utilizada, um invasor poderá modificar o pedido de Bob, fazendo-o comprar dez vezes mais frascos de perfume do que o desejado.
- Se nenhuma autenticação de servidor for usada, um servidor pode exibir o famoso logotipo da Alice Incorporated, quando na verdade o site é mantido por Trudy, que está se passando por Alice Incorporated. Após receber o pedido de Bob, Trudy pode pegar o dinheiro dele e fugir. Ou Trudy pode realizar um roubo de identidade coletando o nome, endereço e número do cartão de crédito de Bob.

O TLS aborda essas questões aprimorando o TCP com confidencialidade, integridade de dados, autenticação de servidor e autenticação de cliente.

O TLS é frequentemente usado para fornecer segurança a transações que ocorrem via HTTP. No entanto, como o TLS protege o TCP, ele pode ser empregado por qualquer aplicativo que execute sobre TCP. O TLS fornece uma Interface de Programação de Aplicativos (API) simples com soquetes, que é semelhante e análoga à API do TCP. Quando um aplicativo deseja empregar o TLS, o aplicativo inclui classes/bibliotecas SSL. Como mostrado na Figura 1, embora o TLS resida tecnicamente na camada de aplicativo,

da perspectiva do desenvolvedor, ele é um protocolo de transporte que fornece os serviços do TCP aprimorados com serviços de segurança.

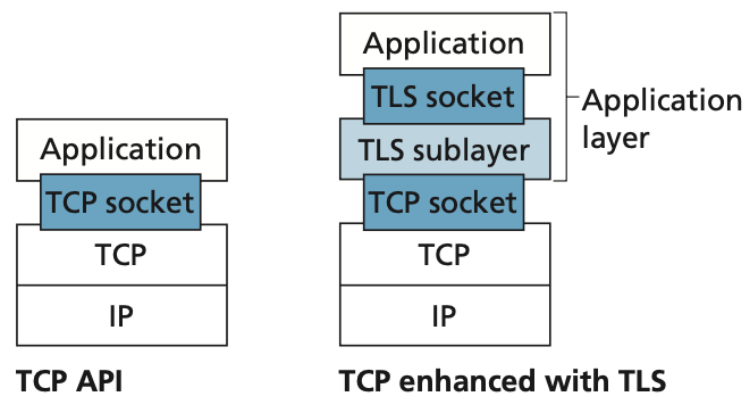


Figura 1

Para entender o TLS, iniciaremos o estudo por um quase-TLS (e o TLS), que possui três fases: handshake, derivação de chaves e transferência de dados.

Handshake

Durante a fase de handshake, Bob precisa (a) estabelecer uma conexão TCP com Alice, (b) verificar se Alice é realmente Alice e (c) enviar a Alice uma chave secreta mestra, que será usada por Alice e Bob para gerar todas as chaves simétricas necessárias para a sessão TLS. Essas três etapas são mostradas na Figura 2. Observe que, uma vez estabelecida a conexão TCP, Bob envia uma mensagem de "hello" para Alice. Alice então responde com seu certificado, que contém sua chave pública. Como o certificado foi certificado por uma CA, Bob tem certeza de que a chave pública no certificado pertence a Alice. Bob então gera um Master Secret (MS) (que será usado apenas para esta sessão TLS), criptografa o MS com a chave pública de Alice para criar o EMS (Encrypted Master Secret (Segredo Mestre Criptografado)) e o envia para Alice. Alice descriptografa o EMS com sua chave privada para obter o MS. Após essa fase, Bob e Alice (e ninguém mais) conhecem o segredo mestre desta sessão TLS.

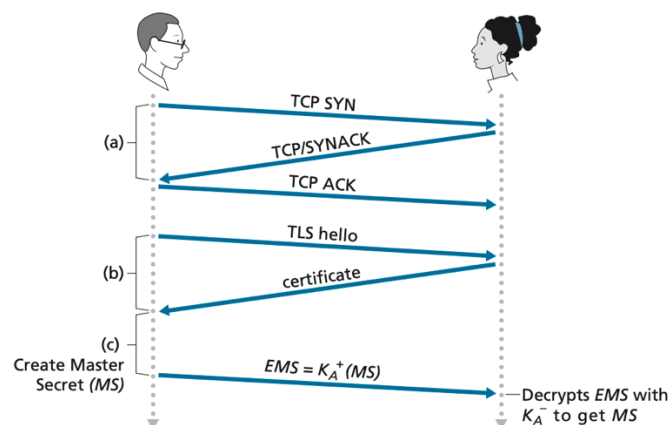


Figura 2

Derivação da Chave

Em princípio, o MS, agora compartilhado por Bob e Alice, poderia ser usado como a chave de sessão simétrica para todas as criptografias e verificações de integridade de dados subsequentes. No entanto, geralmente é considerado mais seguro para Alice e Bob usarem chaves criptográficas diferentes, e também chaves diferentes para criptografia e verificação de integridade.

Assim, Alice e Bob usam o MS para gerar quatro chaves:

- EB = chave de criptografia de sessão para dados enviados de Bob para Alice
- MB = chave HMAC de sessão para dados enviados de Bob para Alice, onde HMAC [RFC 2104] é um código de autenticação de mensagens com hash (MAC) padronizado.
- EA = chave de criptografia de sessão para dados enviados de Alice para Bob
- MA = chave HMAC de sessão para dados enviados de Alice para Bob

Alice e Bob geram as quatro chaves do MS. Ao final da fase de derivação da chave, Alice e Bob possuem todas as quatro chaves. As duas chaves de criptografia serão usadas para criptografar os dados; as duas chaves HMAC serão usadas para verificar a integridade dos dados.

Transferência de Dados

Agora que Alice e Bob compartilham as mesmas quatro chaves de sessão (EB, MB, EA e MA), eles podem começar a enviar dados seguros um para o outro pela conexão TCP. Como o TCP é um protocolo de fluxo de bytes, uma abordagem natural seria o TLS criptografar os dados do aplicativo dinamicamente e, em seguida, repassá-los dinamicamente para o TCP. Mas, se fizéssemos isso, onde seria colocado o HMAC para a verificação de integridade? Certamente não é desejável esperar até o final da sessão TCP para verificar a integridade de todos os dados de Bob que foram enviados durante toda a sessão. Para resolver esse problema, o TLS divide o fluxo de dados em registros, anexa um HMAC a cada registro para verificação de integridade e, em seguida, criptografa o registro + HMAC. Para criar o HMAC, Bob insere os dados do registro, juntamente com a chave MB, em uma função hash, conforme discutido na Seção 8.3. Para criptografar o registro do pacote + HMAC, Bob usa sua chave de criptografia de sessão EB. Esse pacote criptografado é então passado para o TCP para transporte pela Internet.

Embora essa abordagem seja bastante abrangente, ela ainda não é infalível quando se trata de fornecer integridade de dados para todo o fluxo de mensagens. Em particular, suponha que Trudy seja uma intermediária e tenha a capacidade de inserir, excluir e substituir segmentos no fluxo de segmentos TCP enviados entre Alice e Bob. Trudy, por exemplo, poderia capturar dois segmentos enviados por Bob, inverter a ordem dos segmentos, ajustar os números de sequência TCP (que não são criptografados) e, em seguida, enviar os dois segmentos em ordem reversa para Alice. Supondo que cada segmento TCP encapsula exatamente um registro, vamos agora dar uma olhada em como Alice processaria esses segmentos.

1. O TCP em execução em Alice consideraria que tudo está bem e passaria os dois registros para a subcamada TLS.
2. O TLS em Alice descriptografaria os dois registros.

3. O TLS em Alice usaria o HMAC em cada registro para verificar a integridade dos dados dos dois registros.
4. O TLS então passaria os fluxos de bytes descryptografados dos dois registros para a camada de aplicação; mas o fluxo completo de bytes recebido por Alice não estaria na ordem correta devido à reversão dos registros.

Situações similares podem acontecer para quando Trudy remove segmentos ou quando Trudy reproduz segmentos. A solução para esse problema é usar números de sequência. O TLS faz isso da seguinte maneira. Bob mantém um contador de números de sequência, que começa em zero e é incrementado para cada registro TLS que ele envia. Bob não inclui um número de sequência no próprio registro, mas quando calcula o HMAC, ele inclui o número de sequência no cálculo do HMAC. Assim, o HMAC agora é um hash dos dados mais a chave HMAC MB mais o número de sequência atual. Alice rastreia os números de sequência de Bob, permitindo que ela verifique a integridade dos dados de um registro, incluindo o número de sequência apropriado no cálculo do HMAC.

Registro TLS

O registro TLS é mostrado na Figura 3. O registro consiste em um campo de tipo, um campo de versão, um campo de comprimento, um campo de dados e um campo HMAC. Observe que os três primeiros campos não são criptografados. O campo de tipo indica se o registro é uma mensagem de handshake ou uma mensagem que contém dados do aplicativo. Ele também é usado para fechar a conexão TLS. O TLS na extremidade receptora usa o campo de comprimento para extrair os registros TLS do fluxo de bytes TCP de entrada. O campo de versão é autoexplicativo.

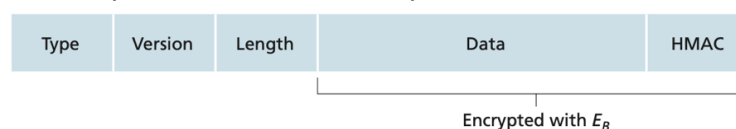


Figura 3

Handshake TLS

O SSL não exige que Alice e Bob utilizem um algoritmo de chave simétrica específico ou um algoritmo de chave pública específico. Em vez disso, o TLS permite que Alice e Bob concordem com os algoritmos criptográficos no início da sessão TLS, durante a fase de handshake. Além disso, durante a fase de handshake, Alice e Bob enviam nonces um ao outro, que são usados na criação das chaves de sessão (EB, MB, EA e MA). As etapas do handshake TLS real são as seguintes:

1. O cliente envia uma lista de algoritmos criptográficos suportados, juntamente com um nonce do cliente.
2. Da lista, o servidor escolhe um algoritmo simétrico (por exemplo, AES) e um algoritmo de chave pública (por exemplo, RSA com um comprimento de chave específico) e um algoritmo HMAC (MD5 ou SHA-1), juntamente com as chaves HMAC. Ele envia de volta ao cliente suas escolhas, bem como um certificado e um nonce do servidor.

3. O cliente verifica o certificado, extrai a chave pública do servidor, gera um Segredo Pré-Mestre (PMS), criptografa o PMS com a chave pública do servidor e envia o PMS criptografado para o servidor.
4. Usando a mesma função de derivação de chave (conforme especificado pelo padrão TLS), o cliente e o servidor calculam independentemente o Segredo Mestre (MS) a partir do PMS e dos nonces. O MS é então fatiado para gerar as duas chaves de criptografia e duas chaves HMAC. Além disso, quando a cifra simétrica escolhida utiliza CBC (como 3DES ou AES), dois Vetores de Inicialização (IVs) — um para cada lado da conexão — também são obtidos do MS. A partir de então, todas as mensagens enviadas entre o cliente e o servidor são criptografadas e autenticadas (com o HMAC).
5. O cliente envia o HMAC de todas as mensagens de handshake.
6. O servidor envia o HMAC de todas as mensagens de handshake.

As duas últimas etapas protegem o handshake contra adulterações. Para ver isso, observe que na etapa 1, o cliente normalmente oferece uma lista de algoritmos — alguns fortes, outros fracos. Essa lista de algoritmos é enviada em texto simples, uma vez que os algoritmos e as chaves de criptografia ainda não foram acordados. Trudy, como uma intermediária, poderia excluir os algoritmos mais fortes da lista, forçando o cliente a selecionar um algoritmo fraco. Para prevenir tal ataque de adulteração, na etapa 5, o cliente envia o HMAC da concatenação de todas as mensagens de handshake enviadas e recebidas. O servidor pode comparar esse HMAC com o HMAC das mensagens de handshake recebidas e enviadas. Se houver alguma inconsistência, o servidor pode encerrar a conexão. Da mesma forma, o servidor envia o HMAC das mensagens de handshake que viu, permitindo que o cliente verifique se há inconsistências.

Os números de sequência não são suficientes para prevenir o ataque de repetição de segmento? A resposta é sim, mas eles não impedem sozinhos o "ataque de repetição de conexão". Considere o seguinte ataque de repetição de conexão. Suponha que Trudy fareje todas as mensagens entre Alice e Bob. No dia seguinte, Trudy se disfarça de Bob e envia para Alice exatamente a mesma sequência de mensagens que Bob enviou para Alice no dia anterior. Se Alice não usar nonces, ela responderá com exatamente a mesma sequência de mensagens que enviou no dia anterior. Alice não suspeitará de nada, pois cada mensagem que receber passará pela verificação de integridade. Se Alice for um servidor de comércio eletrônico, ela pensará que Bob está fazendo um segundo pedido (exatamente para a mesma coisa). Por outro lado, ao incluir um nonce no protocolo, Alice enviará nonces diferentes para cada sessão TCP, fazendo com que as chaves de criptografia sejam diferentes nos dois dias. Portanto, quando Alice recebe registros TLS reproduzidos de Trudy, os registros falharão nas verificações de integridade e a transação de comércio eletrônico falsa não será bem-sucedida. Em resumo, em TLS, nonces são usados para se defender contra o "ataque de repetição de conexão" e números de sequência são usados para se defender contra a repetição de pacotes individuais durante uma sessão em andamento.

Encerramento da Conexão

Em algum momento, Bob ou Alice desejarão encerrar a sessão TLS. Uma abordagem seria deixar Bob encerrar a sessão TLS simplesmente encerrando a conexão TCP

subjacente — ou seja, fazendo com que Bob envie um segmento TCP FIN para Alice. Mas um design tão ingênuo prepara o cenário para o ataque de truncamento, no qual Trudy, mais uma vez, entra no meio de uma sessão TLS em andamento e a encerra antecipadamente com um TCP FIN. Se Trudy fizesse isso, Alice pensaria que recebeu todos os dados de Bob, quando, na verdade, recebeu apenas uma parte deles. A solução para esse problema é indicar no campo de tipo se o registro serve para encerrar a sessão TLS. (Embora o tipo TLS seja enviado em texto não criptografado, ele é autenticado no destinatário usando o HMAC do registro.) Ao incluir esse campo, se Alice recebesse um TCP FIN antes de receber um registro TLS de encerramento, ela saberia que algo estranho estava acontecendo.

Isso conclui nossa introdução ao TLS. Vimos que ele utiliza muitos dos princípios de criptografia discutidos nas Seções 8.2 e 8.3. Leitores que desejam explorar o TLS em um nível ainda mais profundo podem ler o livro de fácil leitura de Rescorla sobre SSL/TLS [Rescorla 2001].

IPSEC

O protocolo de segurança IP, mais comumente conhecido como IPsec, fornece segurança na camada de rede. O IPsec protege datagramas IP entre quaisquer duas entidades da camada de rede, incluindo hosts e roteadores. Como descreveremos em breve, muitas instituições usam o IPsec para criar redes privadas virtuais (VPNs) que operam na Internet pública.

Com a confidencialidade da camada de rede entre um par de entidades de rede (por exemplo, entre dois roteadores, entre dois hosts ou entre um roteador e um host), a entidade emissora criptografa as cargas úteis de todos os datagramas que envia para a entidade receptora. A carga útil criptografada pode ser um segmento TCP, um segmento UDP, uma mensagem ICMP e assim por diante. Com tal serviço de camada de rede, todos os dados enviados de uma entidade para a outra — incluindo e-mails, páginas da Web, mensagens de handshake TCP e mensagens de gerenciamento (como ICMP e SNMP) — seriam ocultados de qualquer terceiro que pudesse estar espionando a rede. Por esse motivo, diz-se que a segurança da camada de rede fornece "cobertura geral".

Além da confidencialidade, um protocolo de segurança da camada de rede poderia potencialmente fornecer outros serviços de segurança. Por exemplo, ele poderia fornecer autenticação de origem, para que a entidade receptora pudesse verificar a origem do datagrama protegido. Um protocolo de segurança da camada de rede poderia fornecer integridade de dados, para que a entidade receptora pudesse verificar qualquer adulteração do datagrama que pudesse ter ocorrido enquanto o datagrama estava em trânsito. Um serviço de segurança da camada de rede também poderia fornecer prevenção contra ataques de repetição, o que significa que Bob poderia detectar quaisquer datagramas duplicados que um invasor pudesse inserir.

IPsec e Redes Privadas Virtuais (VPNs)

Uma instituição que se estende por várias regiões geográficas frequentemente deseja sua própria rede IP, para que seus hosts e servidores possam enviar dados entre si de

forma segura e confidencial. Para atingir esse objetivo, a instituição poderia implantar uma rede física autônoma — incluindo roteadores, links e uma infraestrutura de DNS — completamente separada da Internet pública. Essa rede separada, dedicada a uma instituição específica, é chamada de rede privada. Uma rede privada pode ser muito cara, pois a instituição precisa adquirir, instalar e manter sua própria infraestrutura de rede física.

Em vez de implantar e manter uma rede privada, muitas instituições hoje criam VPNs sobre a Internet pública existente. Com uma VPN, o tráfego entre escritórios da instituição é enviado pela Internet pública, em vez de utilizar uma rede física independente. Mas, para garantir a confidencialidade, o tráfego entre escritórios é criptografado antes de entrar na Internet pública. Um exemplo simples de VPN é mostrado na Figura 4. Aqui, a instituição consiste em uma sede, uma filial e vendedores ambulantes que normalmente acessam a Internet de seus quartos de hotel. (Há apenas um vendedor mostrado na figura.) Nessa VPN, sempre que dois hosts na sede enviam datagramas IP um para o outro ou sempre que dois hosts na filial desejam se comunicar, eles usam o IPv4 padrão (ou seja, sem serviços IPsec). No entanto, quando dois hosts da instituição se comunicam por um caminho que atravessa a Internet pública, o tráfego é criptografado antes de entrar na Internet.

Para entender como uma VPN funciona, vamos analisar um exemplo simples no contexto da Figura 4. Quando um host na sede envia um datagrama IP para um vendedor em um hotel, o roteador de gateway na sede converte o datagrama IPv4 padrão em um datagrama IPsec e, em seguida, encaminha esse datagrama IPsec para a Internet. Esse datagrama IPsec, na verdade, possui um cabeçalho IPv4 tradicional, de modo que os roteadores na Internet pública processam o datagrama como se fosse um datagrama IPv4 comum — para eles, o datagrama é um datagrama perfeitamente comum. Mas, como mostrado na Figura 4, a carga útil do datagrama IPsec inclui um cabeçalho IPsec, que é usado para processamento IPsec; além disso, a carga útil do datagrama IPsec é criptografada. Quando o datagrama IPsec chega ao laptop do vendedor, o sistema operacional do laptop descriptografa a carga útil (e fornece outros serviços de segurança, como a verificação da integridade dos dados) e passa a carga útil não criptografada para o protocolo de camada superior (por exemplo, para TCP ou UDP).

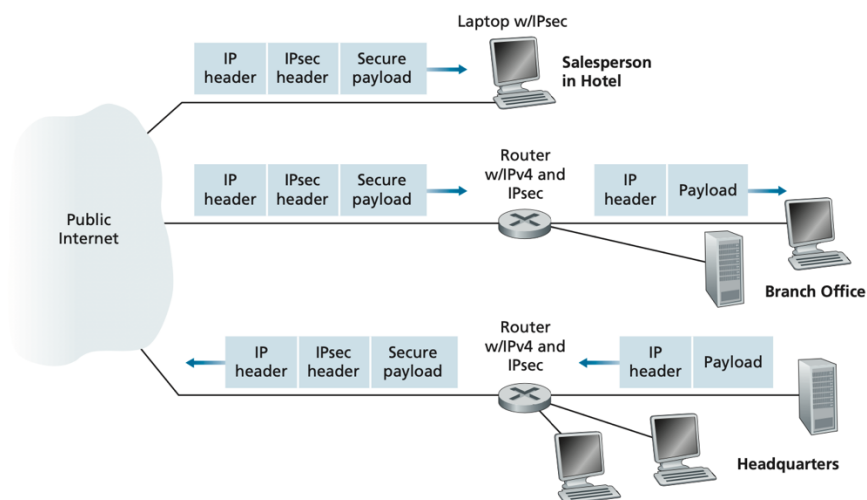


Figura 4

Os Protocolos AH e ESP

O IPsec é definido em mais de uma dúzia de RFCs. Duas RFCs importantes são a RFC 4301, que descreve a arquitetura geral de segurança IP, e a RFC 6071, que fornece uma visão geral do conjunto de protocolos IPsec. No conjunto de protocolos IPsec, existem dois protocolos principais: o protocolo Authentication Header (AH) e o protocolo Encapsulation Security Payload (ESP). Quando uma entidade IPsec de origem (tipicamente um host ou um roteador) envia datagramas seguros para uma entidade de destino (também um host ou um roteador), ela o faz com o protocolo AH ou o protocolo ESP. O protocolo AH fornece autenticação de origem e integridade de dados, mas não fornece confidencialidade. O protocolo ESP fornece autenticação de origem, integridade de dados e confidencialidade. Como a confidencialidade costuma ser crítica para VPNs e outras aplicações IPsec, o protocolo ESP é muito mais amplamente utilizado do que o protocolo AH. Para desmistificar o IPsec este texto abordará exclusivamente o protocolo ESP.

Associações de Segurança

Datagramas IPsec são enviados entre pares de entidades de rede, como entre dois hosts, entre dois roteadores ou entre um host e um roteador. Antes de enviar datagramas IPsec da entidade de origem para a entidade de destino, as entidades de origem e destino criam uma conexão lógica na camada de rede. Essa conexão lógica é chamada de associação de segurança (SA). Uma SA é uma conexão lógica simplex; ou seja, é unidirecional da origem para o destino. Se ambas as entidades desejam enviar datagramas seguros uma para a outra, duas SAs (ou seja, duas conexões lógicas) precisam ser estabelecidas, uma em cada direção.

Por exemplo, considere novamente a VPN institucional na Figura 4. Esta instituição consiste em um escritório central, uma filial e, digamos, n vendedores ambulantes. A título de exemplo, vamos supor que haja tráfego IPsec bidirecional entre a sede e a filial e tráfego IPsec bidirecional entre a sede e os vendedores. Nesta VPN, quantas SAs existem? Para responder a esta pergunta, observe que existem duas SAs entre o roteador de gateway da sede e o roteador de gateway da filial (uma em cada direção); para cada laptop do vendedor, existem duas SAs entre o roteador de gateway da sede e o laptop (novamente, uma em cada direção). Portanto, no total, existem $(2 + 2n)$ SAs. Lembre-se, no entanto, de que nem todo o tráfego enviado para a Internet pelos roteadores de gateway ou pelos laptops será protegido por IPsec. Por exemplo, um host na sede pode querer acessar um servidor Web (como Amazon ou Google) na Internet pública. Assim, o roteador de gateway (e os laptops) emitirão para a Internet tanto datagramas IPv4 padrão quanto datagramas IPsec seguros.

Para tornar a discussão tangível e concreta, vamos fazer isso no contexto de uma SA do roteador R1 para o roteador R2 na Figura 5. (Você pode pensar no Roteador R1 como o roteador de gateway da sede e no Roteador R2 como o roteador de gateway da filial, como mostrado na Figura 4.) O Roteador R1 manterá informações de estado sobre esta SA, que incluirão:

- Um identificador de 32 bits para a SA, chamado Índice de Parâmetros de Segurança (SPI)
- A interface de origem da SA (neste caso, 200.168.1.100) e a interface de destino da SA (neste caso, 193.68.2.23)
- O tipo de criptografia a ser usada (por exemplo, 3DES com CBC)
- A chave de criptografia
- O tipo de verificação de integridade (por exemplo, HMAC com MD5)
- A chave de autenticação

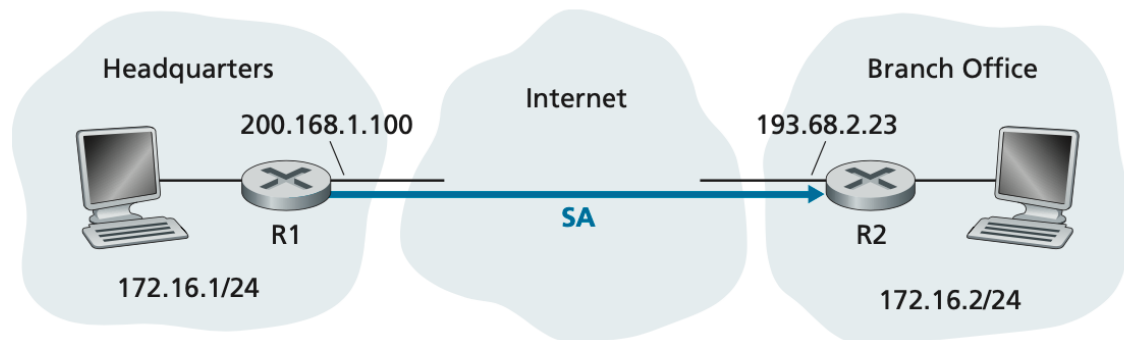


Figura 5

Sempre que o roteador R1 precisa construir um datagrama IPsec para encaminhamento por esta SA, ele acessa essas informações de estado para determinar como deve autenticar e criptografar o datagrama. Da mesma forma, o roteador R2 manterá as mesmas informações de estado para esta SA e as utilizará para autenticar e descriptografar qualquer datagrama IPsec que chegue da SA. Uma entidade IPsec (roteador ou host) frequentemente mantém informações de estado para muitas SAs. Por exemplo, no exemplo de VPN da Figura 4 com n vendedores, o roteador de gateway da matriz mantém informações de estado para $(2 + 2n)$ SAs. Uma entidade IPsec armazena as informações de estado para todas as suas SAs em seu Banco de Dados de Associação de Segurança (SAD), que é uma estrutura de dados no kernel do sistema operacional da entidade.

Datagrama IPsec

O IPsec possui dois formatos de pacote diferentes, um para o chamado modo túnel e outro para o chamado modo transporte. O modo túnel, sendo mais apropriado para VPNs, é mais amplamente utilizado do que o modo transporte. Para desmistificar ainda mais o IPsec e evitar muitas de suas complicações, doravante nos concentraremos exclusivamente no modo túnel. Depois de ter um domínio sólido do modo túnel, você poderá aprender facilmente sobre o modo transporte por conta própria.

O formato do pacote do datagrama IPsec é mostrado na Figura 6. Na Figura 5, suponha que o roteador R1 receba um datagrama IPv4 comum do host 172.16.1.17 (na rede da matriz) com destino ao host 172.16.2.48 (na rede da filial). O roteador R1 usa a seguinte fórmula para converter esse "datagrama IPv4 original" em um datagrama IPsec:

- Acrescenta ao final do datagrama IPv4 original
- Criptografa o resultado usando o algoritmo e a chave especificados pela SA
- Acrescenta à frente desse valor criptografado um campo denominado header ESP; O

pacote resultante é chamado de "enchilada"

- Cria um MAC de autenticação sobre toda a enchilada usando o algoritmo e a chave especificados no SA
- Anexa o MAC ao final da enchilada, formando o payload
- Finalmente, cria um novo cabeçalho IP com todos os campos clássicos de cabeçalho IPv4 (juntos, normalmente com 20 bytes de comprimento), que é anexado antes do payload).

Observe que o datagrama IPsec resultante é um datagrama IPv4 autêntico, com os campos de cabeçalho IPv4 tradicionais seguidos por um payload. Mas, neste caso, o payload contém um cabeçalho ESP, o datagrama IP original, um cabeçalho ESP e um campo de autenticação ESP (com o datagrama original e o cabeçalho ESP criptografados). O datagrama IP original tem 172.16.1.17 para o endereço IP de origem e 172.16.2.48 para o endereço IP de destino. Como o datagrama IPsec inclui o datagrama IP original, esses endereços são incluídos (e criptografados) como parte da carga útil do pacote IPsec. Mas e os endereços IP de origem e destino que estão no novo cabeçalho IP, ou seja, no cabeçalho mais à esquerda do datagrama IPsec? Eles são definidos para as interfaces do roteador de origem e destino nas duas extremidades dos túneis, ou seja, 200.168.1.100 e 193.68.2.23. Além disso, o número do protocolo neste novo campo de cabeçalho IPv4 não é definido como TCP, UDP ou SMTP, mas sim como 50, designando que se trata de um datagrama IPsec usando o protocolo ESP.

Após R1 enviar o datagrama IPsec para a Internet pública, ele passará por vários roteadores antes de chegar a R2. Cada um desses roteadores processará o datagrama como se fosse um datagrama comum — eles desconhecem completamente o fato de que o datagrama transporta dados criptografados por IPsec. Para esses roteadores públicos de Internet, como o endereço IP de destino no cabeçalho externo é R2, o destino final do datagrama é R2.

Tendo analisado um exemplo de como um datagrama IPsec é construído, vamos agora analisar mais detalhadamente os ingredientes da enchilada. Vemos na Figura 5 que o trailer ESP consiste em três campos: preenchimento; comprimento do preenchimento; e próximo cabeçalho. Lembre-se de que as cifras de bloco exigem que a mensagem a ser criptografada seja um múltiplo inteiro do comprimento do bloco. O preenchimento (consistindo em bytes sem sentido) é usado para que, quando adicionado ao datagrama original (junto com os campos comprimento do preenchimento e próximo cabeçalho), a "mensagem" resultante seja um número inteiro de blocos. O campo comprimento do preenchimento indica à entidade receptora quanto preenchimento foi inserido (e, portanto, precisa ser removido). O próximo cabeçalho identifica o tipo (por exemplo, UDP) de dados contidos no campo dados da carga útil. Os dados da carga útil (tipicamente o datagrama IP original) e o cabeçalho ESP são concatenados e, em seguida, criptografados.

Anexado à frente dessa unidade criptografada está o cabeçalho ESP, que é enviado em texto não criptografado e consiste em dois campos: o SPI e o campo de número de sequência. O SPI indica à entidade receptora a SA à qual o datagrama pertence; a entidade receptora pode então indexar seu SAD com o SPI para determinar os algoritmos e chaves de autenticação/descriptografia apropriados. O campo de número de sequência é usado para defesa contra ataques de repetição.

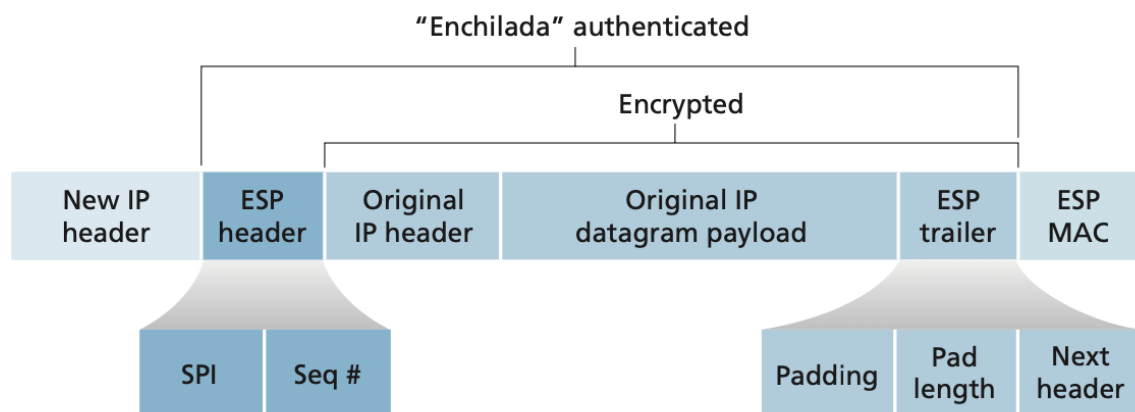


Figura 6

A entidade remetente também anexa um MAC de autenticação. Como mencionado anteriormente, a entidade remetente calcula um MAC sobre toda a enchilada (composta pelo cabeçalho ESP, o datagrama IP original e o trailer ESP — com o datagrama e o trailer criptografados). Lembre-se de que, para calcular um MAC, o remetente anexa uma chave MAC secreta à enchilada e, em seguida, calcula um hash de comprimento fixo do resultado.

Quando R2 recebe o datagrama IPsec, ele observa que o endereço IP de destino do datagrama é o próprio R2. Portanto, R2 processa o datagrama. Como o campo de protocolo (no cabeçalho IP mais à esquerda) é 50, R2 vê que deve aplicar o processamento ESP IPsec ao datagrama. Primeiro, observando a enchilada, R2 usa o SPI para determinar a qual SA o datagrama pertence. Em segundo lugar, ele calcula o MAC da enchilada e verifica se o MAC é consistente com o valor no campo MAC ESP. Em caso afirmativo, ele sabe que a enchilada vem de R1 e não foi adulterada. Terceiro, ele verifica o campo de número de sequência para verificar se o datagrama é novo (e não um datagrama repetido). Quarto, ele descriptografa a unidade criptografada usando o algoritmo de descriptografia e a chave associados à SA. Quinto, ele remove o preenchimento e extrai o datagrama IP original. E, finalmente, sexto, ele encaminha o datagrama original para a rede da filial em direção ao seu destino final. Uau, que receita complicada, hein? Bem, ninguém nunca disse que preparar e desvendar uma enchilada era fácil!

Na verdade, há outra sutileza importante que precisa ser abordada. Ela se concentra na seguinte questão: quando R1 recebe um datagrama (não seguro) de um host na rede da matriz, e esse datagrama é destinado a algum endereço IP de destino fora da matriz, como R1 sabe se ele deve ser convertido em um datagrama IPsec? E se for para ser processado por IPsec, como R1 sabe qual SA (de muitas SAs em seu SAD) deve ser usado para construir o datagrama IPsec? O problema é resolvido da seguinte forma. Junto com um SAD, a entidade IPsec também mantém outra estrutura de dados chamada Banco de Dados de Políticas de Segurança (SPD). O SPD indica quais tipos de datagramas (em função do endereço IP de origem, endereço IP de destino e tipo de protocolo) devem ser processados por IPsec; e para aqueles que devem ser processados por IPsec, qual SA deve ser usado. De certa forma, as informações em um SPD indicam "o que" fazer com um datagrama que chega; as informações no SAD indicam "como" fazê-lo.

Exercícios

1. No registro TLS, há um campo para números de sequência TLS. Verdadeiro ou falso?
2. Qual é a finalidade dos nonces aleatórios no handshake TLS?
3. Suponha que Bob inicie uma conexão TCP com Trudy, que está fingindo ser Alice. Durante o handshake, Trudy envia a Bob o certificado de Alice. Em qual etapa do algoritmo de handshake TLS Bob descobrirá que não está se comunicando com Alice?
4. Considere o envio de um fluxo de pacotes do Host A para o Host B usando IPsec. Normalmente, uma nova SA será estabelecida para cada pacote enviado no fluxo. Verdadeiro ou falso?
5. Suponha que o TCP esteja sendo executado sobre IPsec entre a matriz e a filial na Figura 5. Se o TCP retransmitir o mesmo pacote, os dois pacotes correspondentes enviados por R1 terão o mesmo número de sequência no cabeçalho ESP. Verdadeiro ou falso?
6. Suponha que Alice e Bob estejam se comunicando por meio de uma sessão TLS. Suponha que um invasor, que não possui nenhuma das chaves compartilhadas, insira um segmento TCP falso em um fluxo de pacotes com soma de verificação TCP e números de sequência corretos (e endereços IP e números de porta corretos). O TLS no lado receptor aceitará o pacote falso e passará o payload para o aplicativo receptor? Por que sim ou por que não?
7. Considere o exemplo da Figura 5. Suponha que Trudy seja uma mulher no meio, capaz de inserir datagramas no fluxo de datagramas que vai de R1 para R2. Como parte de um ataque de repetição, Trudy envia uma cópia duplicada de um dos datagramas enviados de R1 para R2. R2 descriptografará o datagrama duplicado e o encaminhará para a rede da filial? Caso contrário, descreva em detalhes como R2 detecta o datagrama duplicado.